1. Authentication & Single Sign-On (Authentik)

Breakdown

- **Central Authentication:** Authentik serves as the primary SSO gateway for Nextcloud, Zulip, MantisBT, and Quotient.
- **Account Separation:** You will manage three separate sets of credentials:
    - **SSO / Auth Account** (for web services)
    - **NETLAB Account** (for your virtual competition network environment)
    - **NISE Account** (for inject distribution/submission)

Strategic Takeaways & Action Items

- **Credential Vaulting:** Prior to the start of the event, designate a password manager or encrypted credential sheet for the team. Ensure everyone logs into Authentik immediately at kickoff to verify access.
- **Isolate Compromise:** If Red Team compromises a machine in your NETLAB environment, your SSO credentials should remain safe—provided you don't reuse passwords across systems. Never use your Authentik password as a local admin/root password on competition virtual machines!

2. Document Collaboration (Nextcloud + Collabora)

Breakdown

- **Multiplayer Documents:** Nextcloud integrated with Collabora provides real-time document and spreadsheet collaboration (similar to Microsoft 365 or Google Docs).
- **Technical Quirks:** Collabora can lag or freeze over prolonged sessions. The recommended fix is clearing local browser cache and restarting the browser.
- **Template Scope:** Custom document templates created in Nextcloud are bound to the specific user account that created them.

Strategic Takeaways & Action Items

- **Standardize Master Templates Ahead of Time:** Have your team lead or primary inject handler log in first, create (or upload) standard inject templates, and share them into a team-wide shared folder. Do not rely on individual user templates, or teammates won't see them!

- **Browser Performance Routine:** Assign a dedicated browser window/profile purely for Nextcloud/Collabora, and keep hardware acceleration/cache management handy if sluggishness occurs under competition pressure.

3. Communication Channels (Zulip)

Breakdown

- **Channel Architecture:** Zulip functions with distinct channels allocated per team function:
  - **Internal Team Channel:** Private blue team discussions.
  - **Support (Green Team) Channel:** Competition ops and logistics.
  - **Orange Team Channel:** Business/customer interaction simulation.
  - **Incident Response (IR / Red Team) Channel:** Reporting compromises and adversary activity.
  - **General Channel:** Open for all teams/organizers (memes, announcements).

Strategic Takeaways & Action Items

- **Streamline Communications:** Set up clear internal roles so your chat doesn't get cluttered:
  - Assign one person to monitor external channels (Green/Orange/Red) to prevent distraction for system administrators focused on hardening.
  - Establish strict message syntax in your internal channel (e.g., `[LINUX]`, `[WINDOWS]`, `[INJECT]`, `[ALERT]`).
- **One-Way Integration Notice:** Remember that MantisBT ticket updates stream *into* Zulip, but posting in Zulip does *not* create or update a support ticket! Do not assume asking a question in Zulip counts as opening a support request.

4. Support Ticketing (MantisBT)

Breakdown

- **Scope of Tickets:** MantisBT is the formal system to request administrative/technical help during the game. This includes:
  - Requesting service scoring checks/confirmations.
  - Requesting virtual machine reverts (if permitted by rules).
  - Requesting Red Team consultations (e.g., post-incident help or defense verification).

- **Integration:** Ticket submissions and updates auto-post to your Zulip support channel.

Strategic Takeaways & Action Items

- **Document Everything for Reverts:** If a service breaks unexpectedly or Red Team locks you out completely, file a ticket immediately through MantisBT. Include full diagnostic screenshots, timestamped logs, and clear justification to speed up Green/White team approvals.
- **Monitor Chat Notifications:** Because MantisBT pushes updates directly to Zulip, keep an eye on your support channel for official ticket status updates without needing to constantly refresh the MantisBT web UI.

5. Service Scoring Engine (Quotient)

Breakdown

- **Primary Function:** Quotient will run in the background as the primary automated engine that polls your network services (HTTP, SSH, DNS, Active Directory, SMTP, etc.) to calculate uptime points.
- **No Injects Here:** Although Quotient can handle injects in some environments, it is explicitly *not* being used for injects in this competition.

Strategic Takeaways & Action Items

- **Prioritize Uptime Checks:** Know exactly what ports and services Quotient checks on your target network. Hardening systems is crucial, but blocking Quotient's polling IPs or breaking service dependencies will cost continuous scoring points.
- **Audit Failed Checks Immediately:** If Quotient registers a service down, immediately use MantisBT or internal triage to fix it before working on secondary low-priority tasks.

6. Inject & Incident Response Engine (NISE)

Breakdown

- **Primary Function:** NISE is used exclusively for task distribution (business tasks/injects) and submitting completed inject responses or Incident Response (IR) reports.
- **Strict Format Requirement:** Submissions **MUST** be in PDF format. No other file extensions (docx, txt, png, zip) will be accepted.

Strategic Takeaways & Action Items

- **Strict PDF Protocol:** Appoint an "Inject Lead" who is responsible for final document review and exporting all Nextcloud documents directly to PDF before uploading to NISE. Submitting an unformatted `.docx` or raw text file will result in an automatic zero score!
- **Track Deadlines:** Injects in NISE carry strict submission deadlines. Missing a deadline by 30 seconds can mean losing all points for a task you spent 45 minutes on. Set internal alarm timers 5–10 minutes prior to NISE deadlines to allow time for formatting and PDF conversion.

Summary Matrix for Team Reference

System	Role	Key Rule / Strategic Action
Authentik	Web SSO Gateway	Separate SSO credentials from internal VM admin passwords.
Nextcloud	Document Prep	Store templates in a **shared team folder**, not personal accounts.
Zulip	Chat Communications	Monitor tickets here, but remember chat replies **do not** update tickets.
MantisBT	Formal Help Requests	Use for scoring disputes, VM revert requests, and Red Team consults.
Quotient	Service Uptime Scoring	Keep scored services running; check immediately if score drops.
NISE	Injects & IR Reports	**PDF formats only**! Respect submission timestamps.

Support Services

Competition Support Status
Central status page to check if support services are down or running normally

https://status.ccdc.events/

Centralized Authentication (Authentik)
Primary homepage and login gateway for all integrated support services

https://auth.ccdc.events/

Authentik Software
Official project website for the Authentik SSO platform

https://goauthentik.io/

Nextcloud Documentation
How-to document for basic instructions on using the Nextcloud environment

https://s.ccdc.events/NextcloudHowTo

Document Collaboration (Nextcloud)
Direct browser access link for real-time document editing

https://docs.ccdc.events/

Nextcloud Platform
Official website for the Nextcloud software

https://nextcloud.com/

Collabora Online
Official website for the Collabora Online (CODE) suite integrated with Nextcloud

https://www.collaboraonline.com/code/

Competition Chat (Zulip)
Direct browser access link for the Zulip chat server

https://chat.ccdc.events/

Zulip Platform
Official website for the Zulip chat system

https://zulip.com/

Support Ticketing (MantisBT)
Direct browser access link to submit and track support requests

https://support.ccdc.events/

MantisBT Platform
Official website for the MantisBT ticketing system

https://mantisbt.org/

Toolkit

1. Windows Hardening & Automation Toolkit

Place these in your repository's `/tools/windows/` directory.

- **HardeningKitty / QuickKitty**
  - **GitHub Link:** https://github.com/scipag/HardeningKitty
  - **What it does:** An assessment and hardening tool for Windows security baselines (acting as a companion to Microsoft Security Compliance Toolkit).
  - **How to run it on Windows (PowerShell):**

PowerShell
```
# Clone or copy into your local repo, then execute:
Set-ExecutionPolicy Bypass -Scope Process -Force
.\HardeningKitty.ps1 -Log -Report -Mode Strict
```

- **DSU DefSec Automation Scripts (`ace`)**
  - **GitHub Link:** https://github.com/EverLand1/ace *(or equivalent local blue-team wrapper scripts)*
  - **What it does:** Rapid user management, service lockdown, and firewall configuration scripts designed for high-pressure competition environments.
  - **How to run it on Windows (PowerShell):**

PowerShell
```
# Run from your local cloned repo folder with administrative
privileges
.\ace-windows-lockdown.ps1 -DisableUnscoredServices -
```

`SecureFirewall`

2. Linux Hardening & Baseline Toolkit

Place these in the repository's `/tools/linux/` directory.

- **Ansible Blue Team Automation Framework**
    - **Concept / Reference:** Inspired by open-source CCDC automation structures, declarative playbooks allow you to enforce identical system baselines across all Linux boxes simultaneously.
    - **How to run it from your management machine (Linux/Bash):**

Bash
```
# Run ansible playbook against your competition inventory
file
ansible-playbook -i inventory.ini site.yml --private-key
~/.ssh/ccdc_admin_key
```

- **Manual Bash Triage Snippets**
    - *Store these as quick-reference scripts (`triage.sh`) in your git repo:*

Bash
```
# Check active listening ports and services
ss -tulpn

# Find all SUID binaries (potential privilege escalation
vectors)
find / -perm -4000 -type f 2>/dev/null

# Check enabled systemd units on boot
systemctl list-unit-files --state=enabled
```

```
# Clone the repository and initialize the deployment script
git clone https://github.com/cisagov/Malcolm.git
cd Malcolm
./scripts/install.py
docker-compose up -d
```

4. Active Directory & Credential Auditing Utilities

Place these in your repository's `/tools/ad/` directory.

- **AutoAD (Rapid Active Directory Setup)**
    - **GitHub Link:** https://github.com/EverLand1/AutoAD *(or lab environment templates)*
    - **What it does:** Automates the deployment and testing of Active Directory domain controllers for pre-competition practice runs.
- **Snafflepy (Credential & Share Auditing)**
    - **GitHub Link:** https://github.com/cisagov/Snafflepy
    - **What it does:** A reconnaissance tool used to find unsecured files, plaintext credentials, and sensitive configurations on internal network shares.
    - **How to run it (Python):**

Bash
```
python3 Snafflepy.py -s 10.10.10.0/24 -d domain.local
```

Repository Structure Recommendation

To keep everything organized when you pull these down into the school's Git repository, structure the folders like this before the clock starts:

Plaintext

```
/ccdc-toolkit/
├── docs/                # SOPs, Rules.md, Credential Policies
├── templates/           # Shared Nextcloud Markdown/docx templates for IR & Injects
├── scripts/
│   ├── windows/         # HardeningKitty, ace scripts, user management
│   └── linux/           # Ansible playbooks, bash triage commands
├── monitoring/          # Malcolm Docker Compose configurations & Zeek parsers
└── tools/               # Snafflepy, AutoAD, and helper utilities
```

Possible Team Roles Based on Special Forces 4 member Team

Member 1: Team Captain & Primary Inject Lead

Focus: Overall Command, NISE Submissions, External Channels, and Windows Domain Controller.

- **Primary Duty:**
  - **Inject Management:** Primary owner of the **NISE** portal. Sets internal 10-minute warning alarms for all inject deadlines, ensures all deliverables are converted strictly to **PDF format**, and uploads submissions on time.

  - **External Communications:** Monitors external Zulip channels (**Support/Green Team**, **Orange Team**, **Incident Response/Red Team**) so technical team members aren't distracted.

  - **Ticketing Lead:** Files formal VM revert requests and scoring dispute tickets via **MantisBT**.

- **Secondary Duty (Technical):**
  - **Windows Active Directory / SSO:** Manages the Active Directory Domain Controller, local account policies, and initial Authentik SSO verification.

    Document Lead: Preps shared Nextcloud folders and master templates at Minute 0.

Member 2: Co-Captain & Linux / Infrastructure Lead

Focus: Linux Hardening, Web/Database Services, and Backup Command.

- **Primary Duty:**
  - **Linux Hardening & Service Maintenance:** Responsible for all Linux boxes (e.g., Ubuntu, Debian, CentOS) running scored web servers (Apache/Nginx), databases (MySQL/PostgreSQL), or SSH services.

  - **Baseline Lockdown:** Executes initial Linux triage (`ss -tulpn`, user account audits, firewall rules) within the first 15 minutes.

- **Secondary Duty (Administrative):**
  - **Co-Captain / Backup Inject Lead:** Serves as the backup liaison to White/Gold teams if the Captain is step-away or busy.

  - **Technical Inject Partner:** Co-authors technical/infrastructure injects alongside Member 1.

Member 3: Network Security & Traffic Analysis Lead

Focus: Perimeter Defense, Firewalls, Logging, and Incident Detection.

- **Primary Duty:**
    - **Network Security Monitoring (NSM):** Deploys and monitors packet capture tools and logging frameworks (e.g., Malcolm / Zeek / Suricata) to detect scans and lateral movement.

    - **Perimeter & Host Firewalls:** Manages host-based firewalls (`ufw`, `firewalld`, Windows Firewall) and ensures active defense measures (like TCP resets) do not block the **Quotient** scoring engine.

- **Secondary Duty:**
    - **Quotient Scoring Watcher:** Continuously monitors the Quotient dashboard for service status drops and alerts system admins immediately when a service goes down.

Member 4: Windows Endpoint & Incident Response (IR) Lead

Focus: Windows Workstations/Member Servers, Forensics, and IR Reports.

- **Primary Duty:**
    - **Windows Endpoint Hardening:** Executes PowerShell hardening scripts (e.g., HardeningKitty/ace) on standalone Windows workstations, IIS servers, or secondary Windows boxes.
    - **Credential Hygiene Enforcement:** Audits local administrator accounts and ensures team members **never** reuse their Authentik SSO password as a local VM password.
- **Secondary Duty (Incident Response):**
    - **Incident Response (IR) Lead:** Lead author on all formal Red Team Incident Reports. Gathers IP addresses, logs, attack timelines, and remediation steps from teammates and compiles the final report for White Team collection to reduce penalty points.

1. **Enforce Internal Chat Etiquette:** Use strict tags in your private Zulip channel (e.g., `[WINDOWS]`, `[LINUX]`, `[INJECT]`, `[RED TEAM]`) to avoid verbal noise in a small room.

2. **Hard Stop at 10 Minutes Before Injects:** No matter what technical task a team member is working on, everything pauses 10 minutes prior to a NISE deadline so Member 1 can review, format to **PDF**, and upload.

S.O.P

Here is a structured Standard Operating Procedure (SOP) checklist breakdown of exact tasks and priorities for the very first seconds and minutes the competition starts.

Phase 0: Zero-Hour Kickoff Checklist (Minutes 0–5)

These steps must happen simultaneously or immediately as the clock starts to establish command and control.

- **Authenticate and Verify Portals:**
    - Immediately log into **Authentik** at the designated URL to verify gateway and web service access.
    - Open and organize browser profiles for **Zulip** (communications) and **MantisBT** (help requests/ticketing).
- **Establish Document Infrastructure:**
    - Open **Nextcloud** and ensure the designated team lead has created the master folders and pre-formatted report templates for incident response (IR) and injects.
- **Assign Team Roles and Monitors:**
    - Confirm everyone knows their assigned workstation (Windows/Linux) and domain responsibilities.
    - Designate a primary **Inject Lead** to track NISE deadlines and enforce PDF export rules.

    - Designate a network/communications watcher to monitor Zulip channels and incoming tickets.

Phase 1: Initial System Triage & Reconnaissance (Minutes 5–15)

Get eyes on what you own, what is running, and what state the machines are in before touching security baselines.

- **Map Listening Services:**
    - On Linux boxes, immediately run `ss -tulpn` or `netstat -tulpn` to list active listening ports.
    - On Windows boxes, run `Get-NetTCPConnection -State Listen` in PowerShell to view active services.
- **Check Scoring Engine Status (Quotient):**
    - Look at the scoring engine dashboard to confirm which services are currently up and earning points. Note baseline uptime.
- **Inventory Local Users and Accounts:**
    - Check for unknown or unauthorized pre-configured local user accounts that the red team or system builders might have left behind.

Phase 2: Immediate Lockdown & Perimeter Defense (Minutes 15–30)

Secure the environment to prevent rapid compromise, keeping scoring uptime in mind.

- **Credential Hygiene & Password Changes:**

    - Change default local administrator and root passwords across all virtual machines immediately.

    - **CRITICAL RULE:** *Never* reuse your central Authentik SSO password as a local root or administrator password on any virtual machine.

- **Implement Host-Based Firewalls:**

    - Enable and configure host-based firewalls (`ufw`, `firewalld`, or Windows Firewall) on individual servers to enforce internal segmentation.

    - Block all inbound traffic except what is strictly required for scored services to function.

- **Protect the Scoring Engine:**

    - Ensure that firewall rules, hardening scripts, or active defense mechanisms (such as TCP resets) do not accidentally block the scoring engine's polling IPs or required ports, which would cause an instant drop in score.

Phase 3: Operational Rhythm & Ongoing Execution (Minute 30 Onward)

Shift from emergency triage to sustained defense and inject management.

- **Inject Management & Deadlines:**

    - Monitor NISE for incoming inject tasks.

    - Set internal team alarms 5 to 10 minutes prior to any NISE deadline to allow time for review and mandatory **PDF export conversion** (unformatted text or raw `.docx` files result in automatic zeros).

- **Ticketing & Disputed Outages:**
    - If a scored service goes down or a machine misbehaves due to a red team compromise, file a formal help request via **MantisBT** (remembering that chat messages on Zulip do not automatically translate into support tickets).
    - Request VM reverts or report issues officially through the proper channel.


OMNISSIAH